

ISYS90090 • CYBERSECURITY MANAGEMENT

Information Security Policy

*The cheapest control to write, and the hardest
control to make real.*

Week 7 • Atif Ahmad • University of Melbourne



This Week in Cybersecurity Management

01

**Study Canvas
Module B**

02

**Prescribed
reading is on
policy, pp. 88 to
104**

03

OPTIONAL

**Answer
discussion
questions on
Canvas, and
chat with peers**

04

**Attend
workshop**

05

OPTIONAL

**Continue
discussion with
peers on Canvas**

This week's workshop

PART A

**Q&A session on this week's
content**

PART B

**Teaching case: Horizon
series**

Intended Learning Objectives

01

Define what is
Information Security
Policy

02

Identify the
motivations for
organisations to
retain an
Information Security
Policy

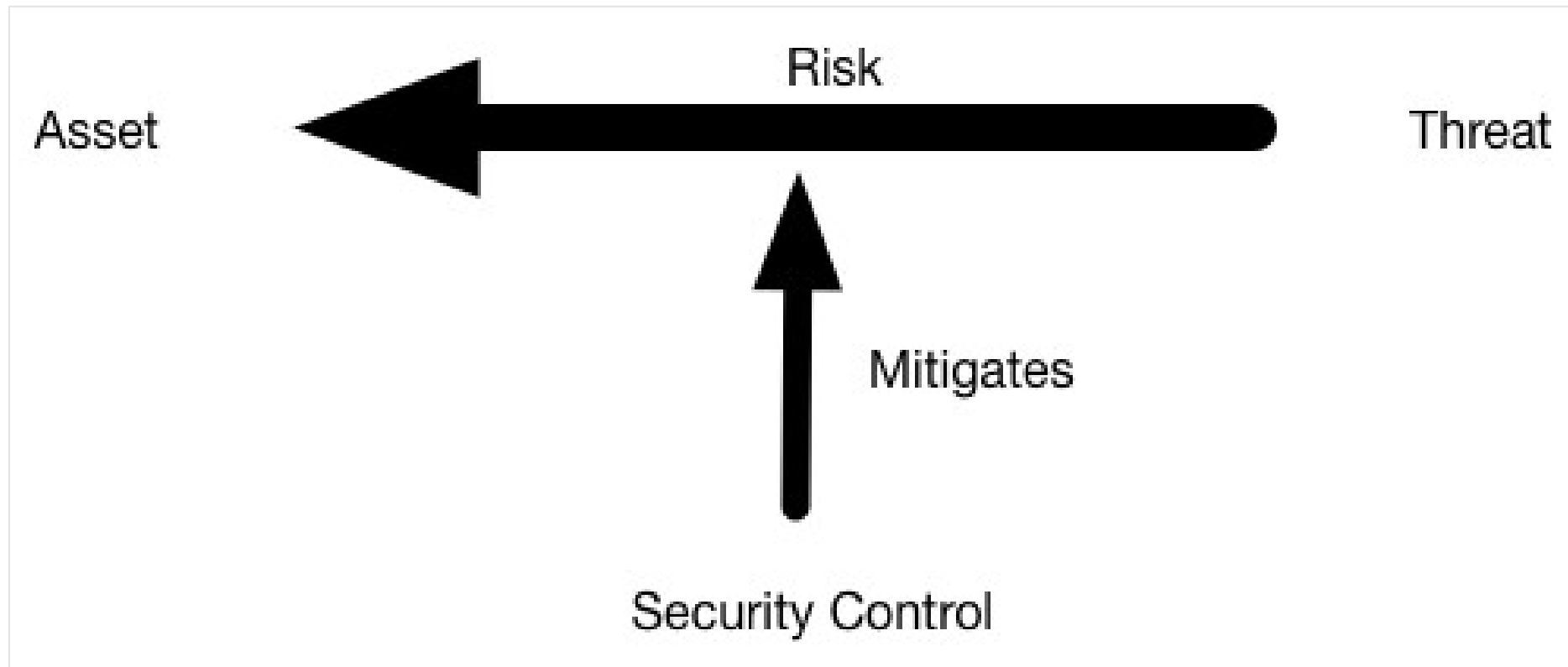
03

Understand the
significant
differences between
an effective and
ineffective
Information Security
Policy

04

Identify at least three
ways in which policy
effectiveness can be
improved

It all starts from the Triplet Model



Asset ← Risk ← Threat, with the security control mitigating the risk.

DEFINITION

What is an Information Security Policy?

WHITMAN AND MATTORD (2012) • THE SIMPLIFIED DEFINITION

Section 2.2 presented Whitman and Mattord's (2012) simplified definition of a policy:

“A policy is a plan or course of action that conveys instructions from an organisation's senior management to those who make decisions, take actions, and perform other duties (p. 177).”

OLSON AND ABRAMS (1995) • THE ELABORATE DEFINITION

The following is Olson and Abrams' (1995) more elaborate definition of policy:

“The set of laws, rules and practices that regulate how an organisation manages, protects and distributes resources to achieve specified security policy objectives. These laws, rules and practices must identify criteria for according individuals authority, and may specify conditions under which individuals are permitted to exercise their authority (p. 161).”

Why bother with a policy?

MARKETING

To demonstrate commitment to information security.

Policy is a necessary part of demonstrating commitment to the board of directors of the firm and the external environment of the organisation and prove that security is taken seriously.

POLITICS / MANAGEMENT

- To clarify the obligations of the organisation
- To set direction for security — emphasising security as being critical in day-to-day operations
- To specify and clarify what the organisation is responsible for
- To influence spending on security (e.g. what are the security priorities and the spending priorities?)
- To provide continuity in management.

Those responsible for security of the organisation, as well as that of employees, are explicitly stated in the policy. Most mature organisations will justify the need for the policy. One particularly important aspect is the explicit priorities in the policy that influence security expenditure.

Why bother with a policy? (2)

PERSONNEL MANAGEMENT

- To formalise grounds for termination and/or prosecution of offenders (e.g. acceptable use of technology)
- To create employee awareness
- To provide a mechanism for stating what behaviour is acceptable
- To stipulate the ramifications of non-conformance with the policy
- To stimulate appropriate conduct.

STANDARDS ACCREDITATION

To be accredited and certified, organisations must have developed an explicit security policy.

Having a security policy is compulsory for most quality accreditations. Not having a security policy is a clear indication that the organisation has not done its due diligence when it comes to security.

Security policy clarifies the bounds of acceptable employee security conduct whilst using a carrot and stick approach to incentivising good behaviour. Penalties for unacceptable behaviour are outlined with clear procedures on the prosecution and eventual termination of offenders.

Why bother with policy? (3)

A quality information security program begins and ends with policy.

Policies are the least expensive means of control — and often the most difficult to implement.

SOME BASIC RULES WHEN SHAPING A POLICY

- 01 **Never conflict with law**
- 02 **Stand up in court**
- 03 **Properly supported and administered**
- 04 **Contribute to the success of the organisation**
- 05 **Involve end users of information systems**

Bull's Eye Model

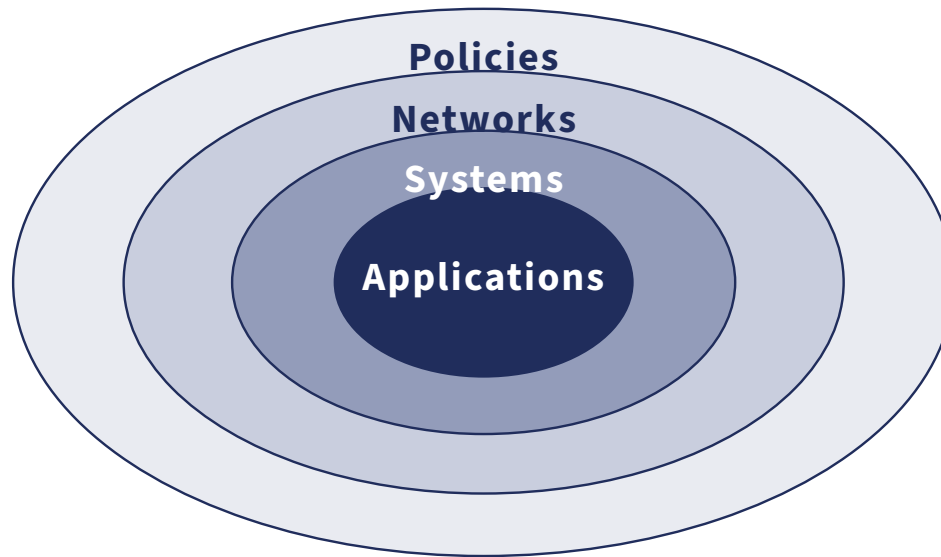


Figure 4-1. The Bull's-Eye Model (Whitman & Mattord).

WORK FROM THE OUTSIDE IN

Policies

Until sound and useable IT and information security policies are developed, communicated and enforced, no additional resources should be spent on other controls.

Networks

Until effective network controls are designed and deployed, all resources should go toward achieving this goal.

Systems

Then focus on the information, process and manufacturing systems — until there is assurance that all critical systems are configured and operated securely.

Applications

Only then move to assessing and remediating the security of the organisation's applications, most critical first.

Types of Policies

Managerial policy

- Security mission, information policy, etc.

Operational policies

- Firewall policy, Backup policy, etc.

Acceptable use policies

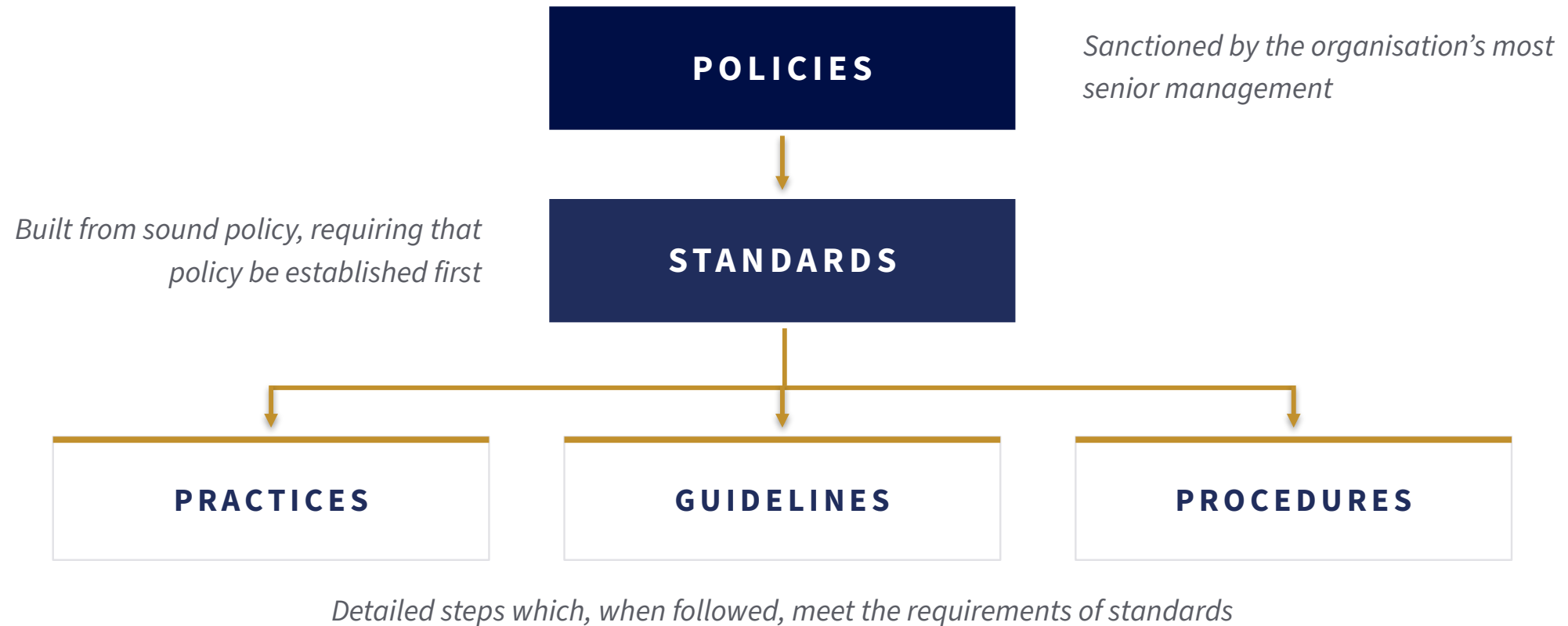
- Internet usage policy, Email policy, etc.

Strategic policy

- Focuses on the strategies of the organisation
- Nearly a combination of aspects from managerial and operational policies
- A grey area

Organisations usually have a number of interconnected policies of the above types.

Policies, Standards & Practices



After Figure 4-2, Policies, Standards and Practices (Whitman & Mattord).

For policies to be effective

READING

Policies must be properly disseminated

How would you disseminate a policy in an organisation?

COMPREHENSION

Policies must be understood by the target audience

How would you ensure that the policy has been understood?

COMPLIANCE

Policies must be agreed upon by the target audience

How would you ensure that employees agree to comply with the policy?

UNIFORM ENFORCEMENT

Policies must be uniformly enforced on the target audience

How would you ensure that the policies have been enforced?

Policies require constant modification and maintenance.

MANAGEMENT MUST DEFINE THREE TYPES OF POLICY

Enterprise information security program policy · Issue-specific information security policies · Systems-specific information security policies

THE POLICY TREE

Typical Policy Document Structure



Measuring Policy Quality

	Definition	Significance Why is it important?	Method of assessment How can policies be tested for it?	Discriminating power What does a 'good' policy look like vs a 'bad' policy?
Completeness	The extent to which the information security policy addresses all security requirements.	Organizations must ensure ALL of their security objectives and directives are met by the policy, i.e. there aren't any gaps or holes.	Map each explicit security objective and directive to particular policy statements.	Completeness depends on the number as well as the criticality of statements that address security objectives and directives.
Suitability	The extent to which the information security policy is appropriate for the organization.	Because every organization is different (org culture, legal, regulatory issues etc) requiring policies to have different characteristics.	May require multiple approaches. Explicit legal and regulatory requirements be mapped to specific policy statements. Suitability to org culture assessed by observing influence on security behaviors.	Notionally, a good policy will complement the organizational culture and effect positive change in security behavior. Also, where legal and regulatory issues are concerned it might be simply a matter of mapping requirements to policy statements.
Accuracy	The extent to which information security policy statements correctly address security requirements.	Vague/erroneous wording can leave org. open to liability, misleading and confusing employees etc.	Policy statements are reviewed by multiple stakeholders including senior management and legal professionals to determine accuracy.	A good policy will (predominantly) consist of statements that correctly address security requirements.
Interoperability	The extent to which information security policy interacts successfully with other organizational policies.	Org. policies should not contradict each other; wording and structure should be similar. Conflict/gaps may allow security breaches.	All org policies that influence or are influenced by security must be reviewed by multiple stakeholders including senior management and legal professionals to determine compatibility and gaps.	A good policy will match structure and wording (e.g. positive reinforcement vs prosecutorial) to support relevant policies in the organization.
Security	The appropriateness of the confidentiality, integrity and availability of the information security policy.	Disclosure of all or part of the policy to unauthorized recipients could be a security risk. However, restricted availability may inhibit compliance because of inadequate circulation.	Confidentiality and availability can be assessed by having security managers and a range of other stakeholders conduct a review of policy statements. The review would focus on potential impact of leakage and need-to-know.	A good policy will not have statements that can facilitate an attack or increase risk of attack to the organization. A good policy will not have statements that impose restrictions on circulation to those who need to know.

Measuring Policy Quality

	Definition	Significance Why is it important?	Method of assessment How can policies be tested for it?	Discriminating power What does a ‘good’ policy look like vs a ‘bad’ policy?
Analyzability	The extent to which information security policy can be methodically examined for deficiencies.	Organizations must be able to examine policy to identify deficiencies.	Policies can be tested for logical flow and modularity. Modular policies featuring a logical break down of topics are relatively easier to analyze than policies with no logic to their structure and spaghetti-like relationships with statements.	A good policy will be structured and worded to facilitate examination and location of a range of topics and statements such as particular risks and the countermeasures.
Stability	The extent to which the information security policy is designed to resist the impact of change.	Policies are frequently revised. Changes to policy should not introduce new and unanticipated problems.	Policies can be tested for logical flow and modularity. Impact of changes made to a logically structured policy are easier to anticipate and correct. Modular policies are more likely to contain or limit the impact of changes.	A good security policy will address security risks through multiple statements (high-level and specific) in case a statement is compromised.
Changeability	The extent to which information security policy can be adapted to changes in environment.	Policies are frequently revised to meet new regulations, standards or business processes. The ability of the policy to be changed is important.	Policies can be tested for logical flow and modularity. Modular policies are easier to change as there is a stronger likelihood that related statements will be in one section or location.	A good security policy is organized logically and systematically so necessary changes can be made efficiently and with minimal restructuring of the rest of the policy.
Testability	The extent to which the effectiveness of the information security policy can be determined (when changes occur).	Organizations must be able to identify issues with the security policy prior to deployment.	Policies can be tested for logical flow and modularity. Policy modules may be deployed without the need for the entire policy to be deployed.	A good policy can be deployed easily so feedback on its effectiveness can be generated quickly.

Discussion — what does a more deploy-able policy look like? Is it more modular, as opposed to spaghetti-like?

WALKTHROUGH

Sample policy document

Walkthrough of ANZ Bank's Security Policy (circa 2004/2005)

PERMISSIONS

Permission to use ANZ Policy (circa 2004/5) for teaching purposes granted by ANZ CISO (4/10/2023).

Final thoughts

Many objectives, one policy

Declaration of intent and commitment, legal obligations, delegation of responsibility, spending priorities, personnel procedures, and more.

THE GAP THAT MATTERS

Official Security Policy vs Unofficial Security Policy — policy frequently clashes with culture.

AND FOUR THINGS TO CARRY OUT OF THE WEEK

■ Cheap to create, difficult to implement

The wordsmithing costs little; operationalising it costs a great deal.

■ It should not exist in a vacuum

Policy only works alongside risk assessment, SETA and technical controls.

■ It utilises a trickle-down effect

Policy → procedure → guidelines.

■ Generational and cultural differences

How policy is read and received is not uniform across an organisation.

Q&A

Questions on policy — and on why the cheapest control is so often the one that fails.

